Bell Cyber

SANS Secure Coding Practices Mapping

Companion mapping to the Bell Cyber Secure Code Review of Splunk security_content

Field	Value
Prepared by	Bell Cyber STIRT
Repository	bellcodereview/security_content @ 4cd62e8
Assessment date	2026-10-06
Classification	Confidential

Confidentiality notice. This document contains the results of an authorized security assessment and describes exploitable weaknesses. Distribution is restricted to the assessment sponsor and the engineering owners of the reviewed repository.

SANS Secure Coding Practices Mapping

This document maps every finding from the Bell Cyber secure code review of the Splunk `security_content` repository to the SANS/CERT Secure Coding Practices checklist. It is a companion to the full report; the finding identifiers (for example PB2-01) resolve to the detailed write-ups in Section 4 of that report. The finding catalogue is repeated below for reference, followed by the mapping.

Finding catalogue

ID	Title	Severity	CVSS	Area
DEP-02	Unpinned pip install in a scheduled job holding long-lived AWS keys that writes the shared app-binaries bucket	High	8.6	Dependencies
PB1-02	CrowdStrike RTR command-argument injection and path traversal via raw path/pid inputs	High	8.5	SOAR playbooks
PB2-03	PowerShell command injection via unquoted filepath in internal_host_winrm_log4j_respond	High	8.3	SOAR playbooks
PB1-01	CrowdStrike FQL filter injection via playbook_input:device (10 playbooks)	High	8.2	SOAR playbooks
CI-01	Script injection via github.head_ref interpolated into run: steps (unit-testing workflow)	High	8.1	CI/CD
CI-02	Untrusted fork-PR code built and executed on a large runner; PR-built artifacts uploaded	High	8.1	CI/CD
PB1-03	Destructive response actions (account disable/enable, quarantine, kill, delete, block, global prevent IOC) with no approval gate or allow-list	High	8.1	SOAR playbooks
PB2-01	OS command injection via ip_or_hostname in SSH investigate playbooks	High	8.0	SOAR playbooks
PB2-02	OS command injection via filepath in internal_host_ssh_log4j_respond	High	8.0	SOAR playbooks
PB2-04	Command injection and arbitrary file deletion via filePath in delete_detected_files (no approval gate)	High	8.0	SOAR playbooks
PB1-06	Hard-coded AWS IAM console password applied to every re-enabled user (public repository)	High	7.4	SOAR playbooks
PB2-10	Destructive automated response with no approval gate or protected-entity allow-list	High	7.4	SOAR playbooks
PB2-09	Attacker-steerable host shutdown and network isolation in the log4j respond pack	High	7.1	SOAR playbooks
DEP-01	Build toolchain dependency tree unlocked: 65 transitive packages float with no lockfile or hashes	Medium	6.8	Dependencies
DEP-05	All 28 GitHub Action references use mutable major tags; third-party actions run with PAT and AWS keys	Medium	6.7	Dependencies
CF-01	Unescaped input interpolated into SOAR REST _filter_* query strings (filter/parameter injection)	Medium	6.5	SOAR custom functions
CF-02	container_update mass-assignment via input_json	Medium	6.5	SOAR custom

ID	Title	Severity	CVSS	Area
	with no key allow-list			functions
CI-03	Splunkbase session token printed to CI logs by ta_update.py	Medium	6.5	CI/CD
PB2-08	Cleartext new password written into a SOAR container comment and action output	Medium	6.5	SOAR playbooks
PB2-06	SPL injection via untrusted CEF fields in Splunk run query templates (multiple playbooks)	Medium	6.3	SOAR playbooks
APP-01	SPL injection via weakly-quoted dashboard token $story$ (ESCU summary dashboard)	Medium	6.1	Splunk app and dashboards
APP-02	SPL injection via unquoted $policyname$/$eventcode$ tokens with auto-run on load (AppLocker dashboard)	Medium	6.1	Splunk app and dashboards
DEP-03	Splunk apps, attack data and container images downloaded without integrity verification from mutable locations	Medium	6.1	Dependencies
CF-03	TLS verification disabled on every custom-function REST call (30+ sites)	Medium	5.9	SOAR custom functions
PB2-07	Non-cryptographic PRNG used to generate the new Active Directory password	Medium	5.9	SOAR playbooks
DET-03	New-IP and spike detections write their own allow-list from attacker-influenced events (self-poisoning)	Medium	5.8	Detection content
PB2-05	Raw IP address passed as the whole Splunk/Carbon Black query (hunting.py)	Medium	5.8	SOAR playbooks
DEP-04	End-of-life components: Splunk 9.3 test image (EOL 2026-07-24), Python 3.10 CI runtime (EOL 2026-10-01), legacy SOAR exports, notebook stacks	Medium	5.6	Dependencies
CF-06	regex_filter_list uses prefix-anchored re.match for keep/drop filtering (allow-list bypass)	Medium	5.4	SOAR custom functions
CF-09	container_merge: unauthorised close/merge/evidence on attacker-influenced container IDs (IDOR)	Medium	5.4	SOAR custom functions
PB1-07	Attacker-controlled e-mail Message-ID drives tenant-wide search, delete and restore (MS Graph, Gmail)	Medium	5.4	SOAR playbooks
CF-04	zip_extract: uncapped decompression (zip-bomb DoS) and no temp cleanup; Zip-Slip not exploitable	Medium	5.3	SOAR custom functions
CF-05	ReDoS via user-supplied regex compiled in regex_filter_list and regex_split	Medium	5.3	SOAR custom functions
CF-07	regex_extract_email: polynomial backtracking and incorrect extraction of attacker-controlled domains	Medium	5.3	SOAR custom functions
CI-05	XML parsing of remote responses without defusedxml and HTTP requests without timeout (ta_update.py)	Medium	5.3	CI/CD
DET-02	SPL injection in potential_password_in_username via attacker-chosen username passed through map	Medium	5.3	Detection content
DET-04	Previously-seen baselines and their consumers form an allow-list poisoning path (30 files)	Medium	5.3	Detection content

ID	Title	Severity	CVSS	Area
DET-06	Case-sensitive match()/LIKE on attacker-controlled fields allows trivial bypass	Medium	5.3	Detection content
DET-07	Hard-coded placeholder domain internal_test_email.com ships as live detection logic (dead detections)	Medium	5.3	Detection content
PB1-08	Cisco Talos Untrusted verdict never maps to Malicious (unstrusted typo) - fail-open scoring	Medium	5.3	SOAR playbooks
PB1-05	ServiceNow sysparm_query (encoded query and URL parameter) injection via search_term	Medium	5.0	SOAR playbooks
DET-05	ES drilldown and risk-message $field$ tokens are substituted unquoted (1,971 detections; one uses |s)	Medium	4.3	Detection content
PB1-04	LDAP filter injection in AD LDAP Entity Attribute Lookup	Medium	4.2	SOAR playbooks
DEP-06	Licence compliance gaps: GPL-3.0-derived datasets redistributed under Apache-2.0 without notices; no NOTICE file; build tool licence unknown	Medium	—	Dependencies
CF-11	asset_get_attributes returns the full asset configuration (possible secret exposure)	Low	4.9	SOAR custom functions
PB2-15	Hostname interpolated into PowerShell file paths in internal_host_winrm_investigate	Low	4.4	SOAR playbooks
CF-08	regex_extract_ipv4: unanchored regex extracts wrong or partial IPs used for security decisions	Low	4.3	SOAR custom functions
CF-10	Object-reference inputs acted on without authorisation checks (artifact/indicator/evidence functions)	Low	4.3	SOAR custom functions
CI-08	External tools launched via partial executable path (PATH hijack) in pre-commit hook and scripts	Low	4.2	CI/CD
DET-16	DSDL/MLTK notebooks deserialise models with pickle and torch.load on stale libraries	Low	3.9	Detection content
DEP-10	Unpinned yamlfmt@latest, floating Go toolchain and sibling-directory executable probe in the pre-commit hook	Low	3.8	Dependencies
CF-14	url_parse: unhandled ValueError on malformed port	Low	3.7	SOAR custom functions
DEP-08	Splunk TA pins drift from Splunkbase and from each other (10 apps a major version behind)	Low	3.7	Dependencies
PB2-11	TLS certificate verification disabled on SOAR REST calls (verify=False)	Low	3.7	SOAR playbooks
SEC-03	Incomplete sanitisation of CloudTrail example logs leaks real AWS account IDs, access-key IDs, principals, roles and buckets	Low	3.7	Secrets
SEC-05	Personal data of employees and residential IP addresses embedded in sample logs	Low	3.7	Secrets
SEC-10	Internal infrastructure and cloud-tenant identifiers disclosed (hostnames, private URLs, tenant GUIDs, S3 buckets, playground endpoint)	Low	3.7	Secrets

ID	Title	Severity	CVSS	Area
CI-13	Missing top-level permissions: blocks and use of a personal access token where a scoped token would do	Low	3.5	CI/CD
PB1-10	Attacker-controlled values rendered unescaped into SOAR markdown notes	Low	3.5	SOAR playbooks
PB2-12	Allow-list bypass by self-tagging in aws_disable_user_accounts	Low	3.5	SOAR playbooks
CF-12	debug.py and passthrough.py log full input values (sensitive data to logs)	Low	3.3	SOAR custom functions
CI-09	Bare except: and broad exception handling swallow errors (validate_yaml.py, ta_update.py)	Low	3.3	CI/CD
APP-08	default.meta exports all knowledge objects system-wide with admin/sc_admin write (tampering surface)	Low	3.1	Splunk app and dashboards
CF-13	Validation via assert statements (stripped under python -O)	Low	3.1	SOAR custom functions
CF-15	Missing None/type guards and empty-cell substring logic bug (custom_list_value_in_strings)	Low	3.1	SOAR custom functions
CF-16	base64_decode: fail-open decoding, NUL stripping and non-ASCII drop	Low	3.1	SOAR custom functions
CF-18	zip_extract: unvalidated vault_id used to build the temp extraction path	Low	3.1	SOAR custom functions
CI-10	PR-controlled detection name/exception rendered unescaped into the GitHub step summary	Low	3.1	CI/CD
DEP-09	SOAR playbooks declare no app versions and depend on unversioned community functions and platform-bundled libraries	Low	3.1	Dependencies
DEP-12	Dependency-update automation does not cover pip or docker ecosystems; no SBOM produced with releases	Low	3.1	Dependencies
DET-08	Malformed drilldown SPL in Copilot and Ollama detections (unbalanced quotes)	Low	3.1	Detection content
PB1-09	CrowdStrike Dynamic Analysis URL scoring is dead code or crash-prone (wrong datapaths, zip order)	Low	3.1	SOAR playbooks
PB1-11	Destructive leaf playbooks read raw unfiltered inputs, defeating the preceding filter	Low	3.1	SOAR playbooks
PB1-13	Account dispatch report/tagging logic flaws (only first user tagged, duplicated rows, None crash)	Low	3.1	SOAR playbooks
PB2-13	Hard-coded placeholder email recipient and sender in email_notification_for_malware	Low	3.1	SOAR playbooks
PB2-14	Unsanitised artifact data in notification email body	Low	3.1	SOAR playbooks
DET-12	map subsearches with non-attacker-controlled $token$ substitution (defence-in-depth)	Low	2.6	Detection content
PB1-12	Unguarded dict/list/regex access on connector and artifact data (crash / DoS)	Low	2.6	SOAR playbooks

ID	Title	Severity	CVSS	Area
PB1-14	Shallow-copy bug mislabels interaction artifacts in Automated Email Investigation	Low	2.6	SOAR playbooks
PB1-15	Super-linear regex on endpoint-controlled RTR stdout and invalid escape sequences	Low	2.6	SOAR playbooks
CI-15	Unbounded $ref recursion in validate_response_templates.py	Low	2.3	CI/CD
DET-09	Drilldown tokens not produced by the detection search (102 dead pivots)	Low	2.3	Detection content
APP-07	Lookup CSV cells beginning with formula characters (export-boundary CSV injection surface only)	Low	2.0	Splunk app and dashboards
APP-03	Logic defect: missing leading pipe in remove_valid_domains subsearch	Low	—	Splunk app and dashboards
APP-04	Over-broad placeholder filter macros (search *) and permissive shipped allow-lists	Low	—	Splunk app and dashboards
APP-05	Lookup WILDCARD match_type references a column absent from the CSV (suspicious_ports_list)	Low	—	Splunk app and dashboards
APP-06	Stale and unattributed threat-intelligence lookups (SSLBL, dynamic DNS providers)	Low	—	Splunk app and dashboards
APP-09	Example identity lookups shipped as defaults (domain_controllers, domain_admins)	Low	—	Splunk app and dashboards
APP-12	Response templates: unquoted src_user SPL token and instance-specific asset IDs	Low	—	Splunk app and dashboards
DEP-07	contentctl-ng has no licence metadata, placeholder description and a non-public source repository	Low	—	Dependencies
SEC-08	Secret-prevention controls are weak: no scanner in CI, inert pre-commit hook, incomplete .gitignore	Low	—	Secrets
PB1-16	phantom.debug logs full observable and result structures (investigation data to logs)	Informational	1.8	SOAR playbooks
APP-10	Lookup CSV header hygiene: UTF-8 BOM and leading-space field names	Informational	—	Splunk app and dashboards
APP-13	JSON schemas leave SPL/playbook/cron fields unconstrained; RemovedContent schema lacks additionalProperties:false	Informational	—	Splunk app and dashboards
APP-14	Documentation instructs bypassing pre-commit hooks (git commit --no-verify); yamllint scoped to detections only	Informational	—	Splunk app and dashboards
CF-17	Deprecated naive-UTC datetime APIs and epoch truncation	Informational	—	SOAR custom functions

ID	Title	Severity	CVSS	Area
CI-11	.github/workflows/labeler.yml uses pull_request_target safely (positive control, informational)	Informational	—	CI/CD
CI-12	OpenAPI example values flagged by secret scanners are placeholders (informational)	Informational	—	CI/CD
CI-14	Hard-coded admin password for the throw-away CI Splunk container (informational)	Informational	—	CI/CD
CI-16	bump-yaml.sh follows secure shell practices (positive note)	Informational	—	CI/CD
DET-13	Cleartext http:// references and malformed references in shipped content	Informational	—	Detection content
DET-14	66 production detections validated only by disabled manual tests (attack_data provenance otherwise clean)	Informational	—	Detection content
DET-15	Deprecated and removed content remains in tree; contentctl excludes it from live searches (positive control)	Informational	—	Detection content
DET-18	Playbook metadata references non-existent or mismatched JSON filenames	Informational	—	Detection content
DET-19	Detection identifiers unique; 127 detections with empty data_source (schema conformance otherwise clean)	Informational	—	Detection content
PB1-17	Correctness and dead-code defects (misrouted enrichment dispatch, wrong keys, column mismatch)	Informational	—	SOAR playbooks
PB1-18	Analyst-prompt design weaknesses in the Search-and-Purge playbooks	Informational	—	SOAR playbooks
PB2-16	Bare except and unguarded dictionary/division in result normalisation blocks	Informational	—	SOAR playbooks
PB2-17	Legacy python_version and Classic-editor playbooks carry the ungated destructive patterns	Informational	—	SOAR playbooks
SEC-04	Expired AWS STS temporary credential committed in a sample log	Informational	—	Secrets
SEC-09	Third-party reputation-service URL with alliance key parameters in SOAR playbook sample values	Informational	—	Secrets

SANS Secure Coding Practices coverage

Each finding is classified against the SANS/CERT Secure Coding Practices checklist area it most directly concerns. Areas with no finding are listed as met or not assessed in Section 9.

Practice area	Findings	Count
Input Validation	APP-10, APP-13, CF-02, CF-05, CF-06, CF-07, CF-08, CF-15, CF-16, CI-01, CI-05, DET-06, DET-16, PB1-01, PB1-02, PB1-04, PB1-05, PB1-07, PB1-11, PB1-15, PB2-01, PB2-02, PB2-03, PB2-05, PB2-06, PB2-15	26

Practice area	Findings	Count
Output Encoding	APP-01, APP-02, APP-07, APP-12, CF-01, CI-10, DET-02, DET-05, DET-12, PB1-10, PB2-14	11
Authentication and Password Management	CI-14, PB1-06	2
Session Management	—	0
Access Control	APP-08, CF-09, CF-10, CI-13, DET-03, DET-04, PB1-03, PB1-18, PB2-09, PB2-10, PB2-12	11
Cryptographic Practices	PB2-07	1
Error Handling and Logging	CF-12, CF-13, CF-14, CI-03, CI-09, PB1-09, PB1-12, PB1-16, PB2-08, PB2-16	10
Data Protection	CF-11, CI-12, SEC-03, SEC-04, SEC-05, SEC-09, SEC-10	7
Communication Security	CF-03, DET-13, PB2-11	3
System Configuration	APP-04, APP-05, APP-06, APP-09, APP-14, CI-02, CI-11, DEP-01, DEP-02, DEP-04, DEP-05, DEP-07, DEP-08, DEP-10, DEP-12, DET-07, DET-15, PB2-13, PB2-17	19
Database Security	—	0
File Management	CF-04, CF-18, DEP-03, PB2-04	4
Memory Management	—	0
General Coding Practices	APP-03, CF-17, CI-08, CI-15, CI-16, DEP-06, DEP-09, DET-08, DET-09, DET-14, DET-18, DET-19, PB1-08, PB1-13, PB1-14, PB1-17, SEC-08	17